

PENETRATION TEST REPORT

testphp.vulnweb.com

OVERALL RISK: HIGH

Assessment Date: 12/02/2026

Report Date: 12/02/2026

Prepared By: PurpleTeam AI Security Scanner

Organization: Security Assessment

Security Grade: D (31%)

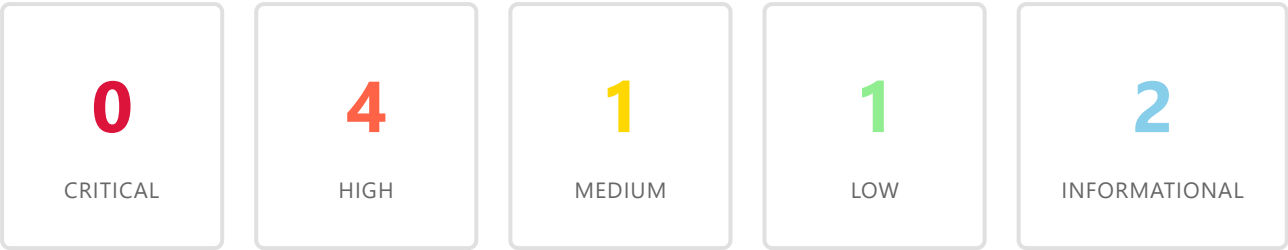
Table of Contents

- 1. Executive Summary
- 2. Scope and Methodology
- 3. Findings Summary
- 4. Detailed Findings
 - 4.1 Sql Injection
 - 4.2 Cross Domain Policy
 - 4.3 Vulners
 - 4.4 Unencrypted HTTP Only (No HTTPS)
 - 4.5 Csrp
 - 4.6 Enum
 - 4.7 Unsafe Output Escaping
 - 4.8 Backup Finder
- 5. Technical Appendix
- 6. Conclusion and Recommendations

1. Executive Summary

This penetration test was conducted on **12/02/2026** against the target **testphp.vulnweb.com**. The assessment identified **8 security vulnerabilities** across various severity levels.

The target system received an overall security score of **31%** (Grade: **D**), indicating a critical security posture.



Overall Risk Assessment: High

The assessment identified 4 high-severity vulnerabilities that represent significant security risks. While not immediately critical, these issues could be exploited to gain unauthorized access or compromise system integrity. Prompt remediation is recommended.

Immediate Action Required: 4 critical/high severity vulnerabilities require immediate remediation to prevent potential system compromise or data breach.

Key Findings

The most significant vulnerabilities discovered include:

- **Sql Injection** (HIGH)
- **Cross Domain Policy** (HIGH)
- **Vulners** (HIGH)
- **Unencrypted HTTP Only (No HTTPS)** (HIGH)
- **Csrf** (MEDIUM)

- ...and 3 additional findings detailed in this report

2. Scope and Methodology

2.1 Assessment Scope

Comprehensive security assessment of testphp.vulnweb.com including network port scanning, service enumeration, and vulnerability detection.

Target System: testphp.vulnweb.com

Assessment Type: Black-box penetration testing with automated vulnerability scanning

2.2 Testing Methodology

The assessment followed industry-standard penetration testing methodologies, including but not limited to:

- Network Port Scanning (Nmap)
- Service Version Detection
- Vulnerability Scanning (NSE Scripts)
- SQL Injection Testing
- Cross-Site Scripting (XSS) Detection
- Common Security Misconfiguration Checks
- SSL/TLS Configuration Analysis
- Web Application Security Testing

2.3 Limitations and Constraints

- Testing was conducted in a controlled environment with explicit authorization
- Social engineering attacks were not performed
- Physical security was not assessed
- Denial of service testing was limited to prevent service disruption
- Testing may not have covered all possible attack vectors

3. Findings Summary

A total of **8 vulnerabilities** were identified during this assessment. The table below provides a high-level overview of all findings:

ID	FINDING	SEVERITY	CVE	OWASP	RISK RATING
FINDING-001	Sql Injection	HIGH	—	—	HIGH (Impact: High, Likelihood: High)
FINDING-002	Cross Domain Policy	HIGH	—	—	HIGH (Impact: High, Likelihood: High)
FINDING-003	Vulners	HIGH	CVE-2026-1642	—	HIGH (Impact: High, Likelihood: High)
FINDING-004	Unencrypted HTTP Only (No HTTPS)	HIGH	—	—	HIGH (Impact: High, Likelihood: High)
FINDING-005	Csrf	MEDIUM	—	—	MEDIUM (Impact: Medium, Likelihood: Medium)
FINDING-006	Enum	LOW	—	—	LOW (Impact: Low, Likelihood: Low)
FINDING-007	Unsafe Output Escaping	INFO	—	—	INFO (Impact: Informational, Likelihood: Low)
FINDING-008	Backup Finder	INFO	—	—	INFO (Impact: Informational, Likelihood: Low)

4. Detailed Findings

This section provides detailed technical information for each identified vulnerability, including description, impact, affected systems, evidence, and remediation recommendations.

FINDING-001

Sql Injection

HIGH

Impact: High

Likelihood: High

Risk Rating: HIGH (Impact: High, Likelihood: High)

Affected Systems: 1

DESCRIPTION

Possible sqli for queries: <http://testphp.vulnweb.com:80/search.php?test=query%27%20OR%20sqlspider>
<http://testphp.vulnweb.com:80/search.php?test=query%27%20OR%20sqlspider> <http://testphp.vulnweb.com:80/search.php?test=query%27%20OR%20sqlspider>
<http://testphp.vulnweb.com:80/search.php?test=query%27%20OR%20sqlspider>
<http://testphp.vulnweb.com:80/listproducts.php?cat=1%27%20OR%20sqlspider> <http://testphp.vulnweb.com:80/search.php?test=query%27%20OR%20sqlspider>
<http://testp>

AFFECTED SYSTEMS/ENDPOINTS

- Port 80/http

IMPACT ANALYSIS

Exploitation could result in unauthorized access to sensitive data, system compromise, or significant security control bypass. Remediation should be prioritized.

TECHNICAL DETAILS

```
Possible sqli for queries:
http://testphp.vulnweb.com:80/search.php?test=query%27%20OR%20sqlspider
http://testphp.vulnweb.com:80/search.php?test=query%27%20OR%20sqlspider
http://testphp.vulnweb.com:80/search.php?test=query%27%20OR%20sqlspider
http://testphp.vulnweb.com:80/search.php?test=query%27%20OR%20sqlspider
http://testphp.vulnweb.com:80/listproducts.php?cat=1%27%20OR%20sqlspider
http://testphp.vulnweb.com:80/search.php?test=query%27%20OR%20sqlspider
http://testp
```

REMEDIATION RECOMMENDATIONS

1. Update http to the latest stable version
2. Review and harden http configuration according to security best practices
3. Implement parameterized queries and prepared statements
4. Apply principle of least privilege to database accounts
5. Enable SQL injection prevention measures (WAF, input validation)

REFERENCES

- OWASP Top 10 2021

FINDING-002

Cross Domain Policy

HIGH

Impact: High	Likelihood: High
Risk Rating: HIGH (Impact: High, Likelihood: High)	Affected Systems: 1

DESCRIPTION

VULNERABLE: Cross-domain and Client Access policies. State: VULNERABLE A cross-domain policy file specifies the permissions that a web client such as Java, Adobe Flash, Adobe Reader, etc. use to access data across different domains. A client acces policy file is similar to cross-domain policy but is used for M\$ Silverlight applications. Overly permissive configurations enables Cross-site Request Forgery attacks, and may allow third parties to access sensitive data m

AFFECTED SYSTEMS/ENDPOINTS

- Port 80/http

IMPACT ANALYSIS

Exploitation could result in unauthorized access to sensitive data, system compromise, or significant security control bypass. Remediation should be prioritized.

TECHNICAL DETAILS

```
VULNERABLE:
  Cross-domain and Client Access policies.
  State: VULNERABLE
    A cross-domain policy file specifies the permissions that a web client such as Java, Adobe Flash,
  Adobe Reader,
    etc. use to access data across different domains. A client acces policy file is similar to cross-
  domain policy
    but is used for M$ Silverlight applications. Overly permissive configurations enables Cross-site
  Request
    Forgery attacks, and may allow third parties to access sensitive data m

Raw Output:
VULNERABLE:
  Cross-domain and Client Access policies.
  State: VULNERABLE
    A cross-domain policy file specifies the permissions that a web client such as Java, Adobe Flash,
  Adobe Reader,
    etc. use to access data across different domains. A client acces policy file is similar to cross-
  domain policy
    but is used for M$ Silverlight applications. Overly permissive configurations enables Cross-site
  Request
    Forgery attacks, and may allow third parties to access se

[Output truncated...]
```

REMEDIATION RECOMMENDATIONS

1. Update http to the latest stable version

2. Review and harden http configuration according to security best practices

REFERENCES

- OWASP Top 10 2021

FINDING-003

Vulners

HIGH

CVE-2026-1642

Impact: High	Likelihood: High
Risk Rating: HIGH (Impact: High, Likelihood: High)	Affected Systems: 1

DESCRIPTION

nginx 1.19.0: 3F71F065-66D4-541F-A813-9F1A2F2B1D91 8.8 <https://vulners.com/githubexploit/3F71F065-66D4-541F-A813-9F1A2F2B1D91> *EXPLOIT* NGINX:CVE-2026-1642 8.2 <https://vulners.com/nginx/NGINX:CVE-2026-1642> NGINX:CVE-2022-41741 7.8 <https://vulners.com/nginx/NGINX:CVE-2022-41741> DF041B2B-2DA7-5262-AABE-9EBD2D535041 7.8 <https://vulners.com/githubexploit/DF041B2B-2DA7-5262-AABE-9EBD2D535041> *EXPLOIT* PACKETSTORM:167720 7.7 <https://vulners.com/packetstorm/PACKETSTORM:167720>

AFFECTED SYSTEMS/ENDPOINTS

- Port 80/http

IMPACT ANALYSIS

Exploitation could result in unauthorized access to sensitive data, system compromise, or significant security control bypass. Remediation should be prioritized.

TECHNICAL DETAILS

```
nginx 1.19.0:
  3F71F065-66D4-541F-A813-9F1A2F2B1D91      8.8      https://vulners.com/githubexploit/3F71F065-66D4-541F-A813-9F1A2F2B1D91
  *EXPLOIT*
  NGINX:CVE-2026-1642      8.2      https://vulners.com/nginx/NGINX:CVE-2026-1642
  NGINX:CVE-2022-41741      7.8      https://vulners.com/nginx/NGINX:CVE-2022-41741
  DF041B2B-2DA7-5262-AABE-9EBD2D535041      7.8      https://vulners.com/githubexploit/DF041B2B-2DA7-5262-AABE-9EBD2D535041
  *EXPLOIT*
  PACKETSTORM:167720      7.7      https://vulners.com/packetstorm/PACKETSTORM:167720

Raw Output:
nginx 1.19.0:
  3F71F065-66D4-541F-A813-9F1A2F2B1D91      8.8      https://vulners.com/githubexploit/3F71F065-66D4-541F-A813-9F1A2F2B1D91
  *EXPLOIT*
  NGINX:CVE-2026-1642      8.2      https://vulners.com/nginx/NGINX:CVE-2026-1642
  NGINX:CVE-2022-41741      7.8      https://vulners.com/nginx/NGINX:CVE-2022-41741
  DF041B2B-2DA7-5262-AABE-9EBD2D535041      7.8      https://vulners.com/githubexploit/DF041B2B-2DA7-5262-AABE-9EBD2D535041
  *EXPLOIT*
  PACKETSTORM:167720      7.7      https://vulners.com/packetstorm/PACKE

[Output truncated...]
```

REMEDIATION RECOMMENDATIONS

1. Update http to the latest stable version
2. Review and harden http configuration according to security best practices

REFERENCES

- <https://nvd.nist.gov/vuln/detail/CVE-2026-1642>
- OWASP Top 10 2021

FINDING-004

Unencrypted HTTP Only (No HTTPS)

HIGH

Impact: High

Likelihood: High

Risk Rating: HIGH (Impact: High, Likelihood: High)

Affected Systems: 1

DESCRIPTION

The server only serves content over unencrypted HTTP. No HTTPS (port 443) was detected. All data including credentials and session cookies are transmitted in cleartext, vulnerable to interception via man-in-the-middle attacks.

AFFECTED SYSTEMS/ENDPOINTS

- Port 80/http

IMPACT ANALYSIS

Exploitation could result in unauthorized access to sensitive data, system compromise, or significant security control bypass. Remediation should be prioritized.

TECHNICAL DETAILS

```
The server only serves content over unencrypted HTTP. No HTTPS (port 443) was detected. All data including credentials and session cookies are transmitted in cleartext, vulnerable to interception via man-in-the-middle attacks.
```

```
Raw Output:  
HTTP port(s) open: 80. No HTTPS port detected.
```

REMEDIATION RECOMMENDATIONS

1. Update http to the latest stable version
2. Review and harden http configuration according to security best practices

REFERENCES

- OWASP Top 10 2021

FINDING-005

Csrf

MEDIUM

Impact: Medium	Likelihood: Medium
Risk Rating: MEDIUM (Impact: Medium, Likelihood: Medium)	Affected Systems: 1

DESCRIPTION

Spidering limited to: maxdepth=3; maxpagecount=20; withinhost=testphp.vulnweb.com Found the following possible CSRF vulnerabilities: Path: http://testphp.vulnweb.com:80/ Form id: Form action: search.php?test=query Path: http://testphp.vulnweb.com:80/disclaimer.php Form id: Form action: search.php?test=query Path: http://testphp.vulnweb.com:80/index.php Form id: Form action: search.php?test=query Path: http://testphp.vulnweb.com:80

AFFECTED SYSTEMS/ENDPOINTS

- Port 80/http

IMPACT ANALYSIS

This vulnerability could be leveraged to gain additional access or information. Should be addressed in the next remediation cycle.

TECHNICAL DETAILS

```
Spidering limited to: maxdepth=3; maxpagecount=20; withinhost=testphp.vulnweb.com
Found the following possible CSRF vulnerabilities:

Path: http://testphp.vulnweb.com:80/
Form id:
Form action: search.php?test=query

Path: http://testphp.vulnweb.com:80/disclaimer.php
Form id:
Form action: search.php?test=query

Path: http://testphp.vulnweb.com:80/index.php
Form id:
Form action: search.php?test=query

Path: http://testphp.vulnweb.com:80
```

REMEDIATION RECOMMENDATIONS

1. Update http to the latest stable version
2. Review and harden http configuration according to security best practices

REFERENCES

- OWASP Top 10 2021

FINDING-006

Enum

LOW

Impact: Low	Likelihood: Low
Risk Rating: LOW (Impact: Low, Likelihood: Low)	Affected Systems: 1

DESCRIPTION

/admin/: Possible admin folder /login.php: Possible admin folder /clientaccesspolicy.xml: Microsoft Silverlight crossdomain policy /crossdomain.xml: Adobe Flash crossdomain policy /CVS/: Potentially interesting folder w/ directory listing /images/: Potentially interesting folder w/ directory listing /pictures/: Potentially interesting folder w/ directory listing /secured/: Potentially interesting folder /vendor/: Potentially interesting folder w/ directory listing

AFFECTED SYSTEMS/ENDPOINTS

- Port 80/http

IMPACT ANALYSIS

Limited impact on overall security posture. Can be addressed as part of regular security maintenance.

TECHNICAL DETAILS

```
/admin/: Possible admin folder
/login.php: Possible admin folder
/clientaccesspolicy.xml: Microsoft Silverlight crossdomain policy
/crossdomain.xml: Adobe Flash crossdomain policy
/CVS/: Potentially interesting folder w/ directory listing
/images/: Potentially interesting folder w/ directory listing
/pictures/: Potentially interesting folder w/ directory listing
/secured/: Potentially interesting folder
/vendor/: Potentially interesting folder w/ directory listing

Raw Output:
/admin/: Possible admin folder
/login.php: Possible admin folder
/clientaccesspolicy.xml: Microsoft Silverlight crossdomain policy
/crossdomain.xml: Adobe Flash crossdomain policy
/CVS/: Potentially interesting folder w/ directory listing
/images/: Potentially interesting folder w/ directory listing
/pictures/: Potentially interesting folder w/ directory listing
/secured/: Potentially interesting folder
/vendor/: Potentially interesting folder w/ directory listing
```

REMEDIATION RECOMMENDATIONS

1. Update http to the latest stable version
2. Review and harden http configuration according to security best practices

REFERENCES

- OWASP Top 10 2021

FINDING-007

Unsafe Output Escaping

INFO

Impact: Informational

Likelihood: Low

Risk Rating: INFO (Impact: Informational, Likelihood: Low)

Affected Systems: 1

DESCRIPTION

Characters [''] reflected in parameter cat at http://testphp.vulnweb.com:80/listproducts.php?cat=1 Characters [''] reflected in parameter cat at http://testphp.vulnweb.com:80/listproducts.php?cat=4 Characters [''] reflected in parameter cat at http://testphp.vulnweb.com:80/listproducts.php?cat=2 Characters [''] reflected in parameter cat at http://testphp.vulnweb.com:80/listproducts.php?cat=3

AFFECTED SYSTEMS/ENDPOINTS

- Port 80/http

IMPACT ANALYSIS

Informational finding that may aid in security awareness or defense-in-depth strategies.

TECHNICAL DETAILS

```
Characters [''] reflected in parameter cat at http://testphp.vulnweb.com:80/listproducts.php?cat=1
Characters [''] reflected in parameter cat at http://testphp.vulnweb.com:80/listproducts.php?cat=4
Characters [''] reflected in parameter cat at http://testphp.vulnweb.com:80/listproducts.php?cat=2
Characters [''] reflected in parameter cat at http://testphp.vulnweb.com:80/listproducts.php?cat=3
```

Raw Output:

```
Characters [''] reflected in parameter cat at http://testphp.vulnweb.com:80/listproducts.php?cat=1
Characters [''] reflected in parameter cat at http://testphp.vulnweb.com:80/listproducts.php?cat=4
Characters [''] reflected in parameter cat at http://testphp.vulnweb.com:80/listproducts.php?cat=2
Characters [''] reflected in parameter cat at http://testphp.vulnweb.com:80/listproducts.php?cat=3
```

REMEDIATION RECOMMENDATIONS

1. Update http to the latest stable version
2. Review and harden http configuration according to security best practices

REFERENCES

- OWASP Top 10 2021

FINDING-008

Backup Finder

INFO

Impact: Informational

Likelihood: Low

Risk Rating: INFO (Impact: Informational, Likelihood: Low)

Affected Systems: 1

DESCRIPTION

Spidering limited to: maxdepth=3; maxpagecount=20; withinhost=testphp.vulnweb.com
http://testphp.vulnweb.com:80/index.bak

AFFECTED SYSTEMS/ENDPOINTS

- Port 80/http

IMPACT ANALYSIS

Informational finding that may aid in security awareness or defense-in-depth strategies.

TECHNICAL DETAILS

```
Spidering limited to: maxdepth=3; maxpagecount=20; withinhost=testphp.vulnweb.com  
http://testphp.vulnweb.com:80/index.bak
```

Raw Output:

```
Spidering limited to: maxdepth=3; maxpagecount=20; withinhost=testphp.vulnweb.com  
http://testphp.vulnweb.com:80/index.bak
```

REMEDIATION RECOMMENDATIONS

1. Update http to the latest stable version
2. Review and harden http configuration according to security best practices

REFERENCES

- OWASP Top 10 2021

5. Technical Appendix

5.1 Network Services Discovered

The following network services were identified as accessible during the assessment:

Port	Protocol	Service	Version
53	TCP	domain	Unknown
80	TCP	http	1.19.0

5.2 Testing Tools

- Nmap - Network scanner and service detection
- Nmap Scripting Engine (NSE) - Vulnerability scanning
- Gemini AI - Vulnerability analysis and reporting

6. Conclusion and Recommendations

This penetration test identified **8 security vulnerabilities** in the target system **testphp.vulnweb.com**, with an overall risk assessment of **High**.

Immediate Actions Required

The following critical and high-severity vulnerabilities require immediate attention:

1. **Sql Injection** - Update http to the latest stable version
2. **Cross Domain Policy** - Update http to the latest stable version
3. **Vulners** - Update http to the latest stable version
4. **Unencrypted HTTP Only (No HTTPS)** - Update http to the latest stable version

General Security Recommendations

1. **Implement a regular patching schedule** to ensure all systems and applications are up-to-date with the latest security patches.
2. **Deploy defense-in-depth security controls** including firewalls, intrusion detection/prevention systems, and web application firewalls.
3. **Conduct regular security assessments** to identify and remediate vulnerabilities before they can be exploited.
4. **Implement security monitoring and logging** to detect and respond to security incidents quickly.
5. **Provide security awareness training** to all personnel to reduce the risk of social engineering attacks.
6. **Follow the principle of least privilege** for all user accounts and service accounts.
7. **Implement strong authentication mechanisms** including multi-factor authentication where applicable.

Next Steps

It is recommended that:

1. Critical and high-severity vulnerabilities be remediated within 30 days
2. Medium-severity vulnerabilities be addressed within 90 days
3. Low-severity and informational findings be reviewed and addressed as part of the next maintenance cycle
4. A follow-up assessment be conducted after remediation to verify fixes

This report is confidential and intended solely for the use of the recipient organization. Unauthorized disclosure or distribution is prohibited.